蒋汶睿

男 | 26岁 | jarvisxfriday@icloud.com
GitHub: awuawuheiyohei | 常年项目主，可面聊
IT / 安全与合规 / DevSecOps 方向 | 4 年企业级交付经验 | CISSP + PMP + ITILv5

个人优势

• 4 年 IT 交付：2 年企业 IT 负责人（克诺尔 Tier 1 汽车零部件，跨多个地区 全公司员工 受管终端）+ 1 年微软 Premium 技术支持（微创，L2/L3）+ 本科/研究生
• 安全合规实战：ISO 27001 IT 审计、MFA 全员推广、CI/CD 自动化 -90% 耗时、0 起 P0 安全事件
• 端到端项目能力：独立设计 / 开发 / 测试 / 上线 20+ 个全栈项目，涵盖安全合规、身份管理、隐私保护、云安全、数据治理、SRE 实践、LLM 应用
• 技术栈：Python / FastAPI / SQL / Docker / K8s / Tekton / CI-CD / AWS / Azure / GCP / Intune / Entra ID / Zscaler / OIDC / SAML / WebAuthn / LLM 应用
• 语言：CET-6 + 雅思 6.0；微创期间全英文服务 跨多个地区客户

工作经历

2024.02 - 2026.10　克诺尔车辆设备（苏州）有限公司　IT Analyst（APAC IT）

> 管辖范围：APAC 多地区· 轨交 + 商用车 2 BU · 全公司员工 · 受管终端

1. 安全合规治理
• owner ISO 27001:2022 IT 审计全流程（控制映射 / 证据收集 / 内审 / 外审配合），连续两轮
• owner 信息安全策略：MFA 全员推广、终端合规、访问治理、漏洞修复、安全意识培训
• owner IT 风险识别与缓解、事件/问题/变更管理流程（ITILv5 + ServiceNow）
2. DevSecOps 与自动化
• 主导企业 CI/CD 流水线（Python + GitHub Actions + OIDC 联邦身份鉴权，零明文密钥）
• 灰度发布（10% → 50% → 100%）、强制 code review、dry-run 前置校验
• 结果：策略部署耗时显著降低；配套双通道回滚（git revert + 平台侧撤销）
• 方案被集团其他 BU 复用
3. 云安全与零信任
• owner 多云资产合规基线（AWS / Azure / GCP），落地 CIS Benchmark 规则引擎
• owner Zscaler ZIA/ZPA 零信任部署（受管用户 × 4 地区）
• 推动 Entra ID 条件访问策略（风险自适应 + 设备合规前置 + 地理限制）
4. 身份与访问管理（IAM）
• owner Microsoft Entra ID + Active Directory（全公司用户）：用户生命周期、RBAC、特权账户管理（PIM）
• 季度 Access Review（特权账户），离职当天权限回收
5. 事件响应与 on-call
• 24/7 on-call（APAC 时区），主导 2025-09 证书过期应急响应（受影响设备，按时恢复，SLO 4 小时）
• 根因分析：Intune 诊断日志 + Kusto 查询，定位 Azure AD 迁移后 CRL endpoint 未更新防火墙白名单

业绩：
• 0 P0 安全事件（2024-2026）
• 两轮 ISO 27001 审计
• Intune MDM 合规策略覆盖受管终端 / MFA 全员推广
• CI/CD 自动化 -90% 耗时，12 个月零错误
• SharePoint Online 迁移（受管设备 / 3 个月 / 参与执行）

2023.02 - 2024.02　上海微创软件股份有限公司　IT 技术支持（Microsoft Intune Premium）

> 客户范围：APAC 多地区· Premium L2/L3 Support

1. owner Intune 企业 MDM 部署与排错（客户工作流 / 模拟复现 / 远程支持）
2. owner Azure / Office 365 / Dynamics 365 三朵云支持（含 Azure OpenAI / Azure AD）
3. owner 安全漏洞修复机制：OS 策略加固、加密状态核查、合规策略审计
4. owner Edge 策略部署（云端 + 本地 Group Policy）
5. owner Python 安全日志分析脚本 + PowerShell 安全策略部署脚本
6. 全英文 APAC 客户沟通（技术支持 / 远程会议 / 邮件）
7. 创建微软 SME 主题「Intune 安全策略最佳实践」，客户满意度 5/5

项目经历（31 个端到端项目 · 全部 GitHub Public）

安全与合规（Security / GRC · 18 个）

企业风险登记册与量化
`06-enterprise-risk-register`

Beta-PERT 10,000 次 Monte Carlo 模拟 · $155M total Annual Loss Expectancy · 15 个业务系统画像 · 5-tab Dashboard
PIPL 跨境数据合规
`09-pipl-cross-border`
中国 PIPL + GDPR 4 路径决策引擎（网信办评估 / 专业认证 / SCC / 豁免） · DPIA 5 维评分 + 单独同意一票否决 · SCC 合同模板 · SHA-256 证据防篡改
DSAR 数据主体请求管理（GDPR Art.12-22）
`17-dsar-management`
7 类数据主体权利全生命周期 · 身份核验前置闸门（未核验不得检索/导出） · 拒绝须附法定依据 · 多法域时限（EU/UK/CA/CN） · 法条与行业惯例严格区分 · 29 endpoints · 490 tests · 74 smoke · CI 3.11/3.12/3.13
企业 DLP 与数据分级
`10-enterprise-dlp`
4 级数据分类（PUBLIC / INTERNAL / CONFIDENTIAL / RESTRICTED） · 9 个敏感信息检测器（Luhn / ISO 7064 / Shannon Entropy / 云凭据串正则） · 62 项测试
ISO 27001 Gap 评估
`03-iso27001-gap-assessment`
18 个控制项 × 4 域评估框架 · 证据追踪 · 自动重测 · 43 项测试
SOC 2 Type II 持续合规
`04-soc2-continuous-compliance`
Trust Services Criteria 控制测试 · 例外管理 · 证据留存
PCI-DSS v4.0 范围缩减
`05-pci-dss-scope-reduction`
CDE 边界识别 · 网络分段策略 · SAQ 资格评估
IR Playbooks
`01-incident-response-playbooks`
6 类事故场景 · NIST SP 800-61 r2 响应流程 · 沟通模板
SIEM / EDR 检测工程
`02-siem-edr-detection`
Sigma 规则库 · MITRE ATT&CK 映射 · 模拟攻击样本
KQL 威胁检测规则库
`02-kql-detections`
Microsoft Sentinel KQL 检测规则 6 条（Impossible Travel / 特权角色授予 / 批量认证失败 / 批量下载 / Shadow IT / MFA 疲劳） · 误报分析与调优思路
TPRM 供应商风险
`07-tprm-vendor-assessment`
Tier 1/2/3 分级 · CAIQ v4 问卷 · DPA 条款扫描 · 数据流映射
B2B 客户 RFP 知识库
`08-b2b-rfp-kb`
100+ 安全条目 · 纯 Python BM25 + TF-IDF 双引擎 · 引用溯源 · 40 项测试
漏洞生命周期与 SLA
`11-vuln-management-sla`
Trivy / Nessus 解析器 · CVSS + EPSS + KEV 复合风险评分 · SLA 状态机（ON_TRACK / AT_RISK / BREACHED）
漏洞管理平台（风险优先级引擎 · #11 升级版）
`15-vulnerability-management-platform`
不用单一 CVSS —— 叠加 EPSS（被利用概率）+ KEV（在野利用）+ 资产上下文（关键性 / 公网暴露）
• 可审计评分：每条风险分存 5 个组件分量，API 与 Dashboard 均可展开解释，无黑箱打分
• 同一 CVE 打 staging 与打公网核心生产机差 24.5 分，等级直接跨档
• SLA 从 CVSS 分档 + 加速因子推导（KEV 减半 / EPSS>0.5 ×0.7），非风险分单点推导
• Trivy JSON / Nessus CSV / Generic JSON 三种真实格式解析（纯标准库）
• 7 表 SQLite · 14 个 REST 端点 · 76 项 pytest + 33 项 smoke · CI 覆盖 Python 3.11/3.12/3.13
云 IAM / PAM 治理
`12-cloud-iam-pam`
4 大风险检测（通配管理员 / 权限提升 / 缺 MFA / 休眠账户） · JIT Break-Glass 双人审批 · UAR 季度对账
多云 CSPM
`13-multicloud-cspm`
CIS 规则引擎（AWS / Azure / GCP） · 风险加权评分 · 21 项测试
BCP/DR 桌面演练
SOAR 自动化响应平台
`16-soar-automation`
告警摄取去重与关联 · Playbook 编排 · 高危动作人工审批门 · 幂等靠 DB 唯一约束 · 补偿动作回滚 · 误报反馈驱动阈值调优 · 23 endpoints · 206 tests · 72 smoke · CI 3.11/3.12/3.13
`14-bcp-dr-tabletop`
业务影响分析（BIA） · RTO/RPO 分级 · 4 阶段勒索软件推演剧本 · 整改项跟踪

DevOps / SRE / 身份管理

IdM SRE 实验室（30 周路线图· v1.3.0）
`idm-sre-lab`
Apple IdMS 风格身份管理平台 + 完整 SRE 实践
• 协议栈：OAuth2/OIDC（PKCE S256 + refresh rotation + RFC 7662 introspection）· SAML 2.0· WebAuthn
• 可观测性：自写 Prometheus exposition· 4 Golden Signals· 结构化日志 + 告警规则引擎
• 可靠性：SLI/SLO + Error Budget· Chaos Engineering（3 类实验）· Incident Response（10 runbook）· Post-Mortem
• 合规：ISO 27001 / PCI-DSS / STRIDE 威胁建模文档
• 规模：73 endpoints· 202 tests· 34 端到端冒烟测试全通过
V 模型 + Tekton CI/CD 实验室
`vmodel-pipeline`
本地 k3d + Tekton + Argo CD· V 模型双向追溯· 5 stage PipelineRun 全绿· LLM 解读 CI 失败（v_explainer）
Intune 中国网络自动修复
`intune-autopilot-cn-fixer`
ZTI 自动化· 指数退避重试· 错误聚合· 可视化面板（针对中国大陆网络限制设计）
Intune 策略自动化
`intune-policy-automation`
GitHub Actions + OIDC 鉴权· 蓝绿部署· 审计日志

AI / LLM 应用（6 个）

母婴 AI 助手
`mother_care`
端到端 RAG（FastAPI + FAISS + BGE 中文 embedding + DeepSeek-V3）· 医疗答案护栏（高危关键词短路至急救话术）· 三道关卡 KB 入库审核· 钉钉 Stream / 企业微信多通道
中文情感分析平台（对比评测 + LoRA 微调管线）
`18-sentiment-analysis-platform`
• 真实公开数据集（外卖评论 11,987 条，负面 7,987 / 正面 4,000，分层划分 + 标签冲突剔除防泄漏）
• Track A 可解释基线：字符 n-gram + 词典特征 + 逻辑回归 → test macro-F1 0.895（19 秒，纯 CPU）
• Track B LoRA 微调：chinese-roberta-wwm-ext，可训练参数仅 0.289%，MPS 实测 285 秒 / 峰值内存 0.95 GB
• 对比结论（实测负结果）：现成专用模型 zero-shot macro-F1 0.969 优于自建 LoRA 0.898
—— 微调通用基座在 1.2 万条窄域数据上补不回预训练先验，故确立「先跑 zero-shot 建基线再决定是否微调」的工程规范
• 238 tests + 41 smoke· CI 3.11/3.12/3.13
检索式知识库
`ai_knowledge_cockpit`
SQLite + BM25 检索路径不经过 LLM· 1:1 KB↔PDF 审计工具· 494 题 MCQ 题库· 钉钉/企微/飞书多通道
Career Coach
`career-coach`
4 小时学习封顶的调度员· 学习计划生成· 模拟题· 进度追踪
Meeting-to-Action
`meeting-to-action`
音频本地即焚（隐私优先）· 会议纪要 + 待办事项 + 关键决策 4 件套结构化输出
RSS Reader + AI 总结
`rss-reader`
自托管 RSS + LLM 摘要· 关键词优先 + LLM 降级 fallback· 5 子命令 CLI + Web UI

其他

发票智能解析
`invoice-intelligence-mvp`
OCR 兜底 + 置信度评分· 多格式导出
业主数据可视化平台
`dashboard5.0-main`
8 视图 + 自动画像标签 + 预警监测
算法图解
`LJ/algorithms`
二分 / 快排 / 图 / 动态规划 + 真实应用案例

技术栈

类别	技能
后端	Python· FastAPI· SQLAlchemy· RESTful API
前端	Vanilla JS· HTML5 / CSS3· 单页 Dashboard

数据库	SQLite（WAL 模式）· PostgreSQL 基础
DevOps	Docker · K8s / K3s · Tekton · Argo CD · GitHub Actions · CI/CD 设计
云	AWS · Azure · GCP · Intune MDM · Entra ID · Zscaler
身份协议	OAuth2 / OIDC · SAML 2.0 · WebAuthn / FIDO2 · PKCE · RBAC / PAM
安全	ISO 27001 · SOC 2 · PCI-DSS · CIS Benchmark · CVSS · STRIDE · GDPR · PIPL
AI / LLM	RAG（FAISS + embedding）· Prompt 工程 · LLM 应用集成 · 脱敏与护栏
ITSM	ITILv5 · ServiceNow · 事件 / 问题 / 变更管理 · on-call

教育经历

- 江苏理工学院（2018 - 2022） 计算机科学与技术 本科 · 专业排名前 5%
- 特洛伊大学（2019 - 2021） 计算机科学与技术 本科（双学位）
- 班长（大一 / 大三）· 国内二三等奖学金（3 学期）· 国外留学生奖学金（2 年）

资格证书

证书	说明
CISSP	国际注册信息安全专业人员
PMP	项目管理专业人士
ITIL v5 Foundation	IT 服务管理
Microsoft Azure	Azure 管理员认证
CET-6 / 雅思 6.0	英语能力

GitHub

https://github.com/awuawuheiyohei
31 个端到端项目全部开源 · 累计 200+ API endpoints · 800+ 自动化测试 · 全部含 README + 架构说明 + Dashboard